

1/51



File No.: EXP202202960

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

.....

2

FIRST:

.....

2

SECOND:

.....

3

THIRD:

.....

6

FOURTH:

.....

6

BACKGROUND

.....

6

RESULT OF THE INVESTIGATION ACTIONS

.....

7

FIFTH:

.....

15

SIXTH:

.....

15

SEVENTH:

.....

16

EIGHTH:

.....

16

PROVEN FACTS

.....

18

FIRST.

18
SECOND.

18
THIRD.

18
FOURTH.

18
FIFTH.

19
SIXTH.

19
SEVENTH.

19
EIGHTH.

19
NINTH.

20
TENTH.

20
ELEVENTH.

20
LEGAL GROUNDS

21
I Competence
'''

21
II Preliminary Issues

21

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

2/51

III Response to the allegations regarding the breach of Article 13 GDPR

.....

22

IV Response to the allegations regarding the breach of Article 32 GDPR

.....

25

V Response to the allegations regarding the breach of Article 35 GDPR

27

VI Unfulfilled information obligation. Article 13 GDPR

.....

29

VII Lack of information. Article 13 GDPR Qualification and classification of the infringement

.....

32

VIII Lack of information. Article 13 GDPR. Sanction

.....

33

IX Lack of security measures. Article 32 GDPR. Unfulfilled obligation

.....

33

X Qualification and classification for the purposes of the prescription of the infringement of Article 32 of the GDPR

.....

36

XI Lack of security measures Article 32 GDPR.

.....

37

XII Data protection impact assessment. Article 35 GDPR Unfulfilled obligation

.....

38

XIII Qualification of the infringement of Article 35 GDPR

.....

46

XIV Lack of impact assessment Article 35 GDPR.

.....

47

XV Adoption of measures

.....

47

RESOLVES

:

.....

48

BACKGROUND

FIRST:

A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Data Protection Agency on February 14, 2022. The complaint is directed against CTC EXTERNALIZACIÓN, S.L. with NIF B60924131 (hereinafter, the respondent). The reasons for the complaint are as follows:

It is claimed that the entity CTC EXTERNALIZACIÓN, S.L. has requested biometric data, specifically fingerprints, from employees for the purpose of implementing a timekeeping system based on that data.

It is stated that at the time of collecting the biometric data, it was not communicated that the information was available on the employee portal, located in the most remote part of the application to which not all workers using the new timekeeping system have access.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
...

3/51

Along with the complaint, a printout of emails exchanged between the complaining party and the complained party is submitted.

SECOND:

In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the aforementioned complaint was forwarded to the complained party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on March 14, 2022, as noted in the acknowledgment of receipt in the file.

On March 22, 2022, a response was received by this Agency indicating basically the following:

1. It is a verification/authentication system (one-to-one), not identification (one-to-many).
2. The fingerprint is not stored. The reader generates a numerical identifier that corresponds to the fingerprint. Identifiers are stored, not the fingerprint. An encryption system is used for storage. It is impossible to reproduce the fingerprint from the numerical identifier.
3. The system does not compare fingerprints; it compares the code generated during the reading with the code that is stored.
4. The system relates a number to a numerical identifier that has been created through a hash.
5. No more data than strictly necessary for the purpose of this processing is requested or processed.
6. The data cannot be reused for other purposes and is deleted when no longer necessary.
7. The data processed includes name, surname, employee code, and initial fingerprint, which is transformed into an identification code. The fingerprint as such is deleted.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/51

8. They only store a biometric template that is registered in a central repository for distribution to the

rest of the biometric devices.

9. The central repository is located on an internal server that is not publicly accessible and has restricted access exclusively for the system administrator.

10. Information has been provided regarding the processing of personal data, specifically: the identity of the Data Controller, the legal basis, purposes of the processing, contact of the data protection officer, rights and procedures to exercise them, that no data transfers are made, and the expected retention period. Additionally, the information is provided through the Employee Portal, which is accessible to all Employees. Data protection clauses of the company are provided with employment contracts. An email was sent in October 2021 to employees informing them of the update of data protection policies and their publication on the Employee Portal. The fingerprint access system was activated at the end of December 2021.

11. They have data protection by design: a provider has been selected with software that offers all guarantees in compliance with data protection regulations, with which a contract has been signed as Data Processor.

12. No international data transfers are made. The location is in the EEA.

13. The Impact Assessment carried out is provided, where among other issues:

It is stated that the principle of data minimization is indeed fulfilled because "The purpose intended to be covered requires all the data to be collected and for all persons/affected parties (principle of data minimization)." There is no justification for how this principle is fulfilled.

It is stated that the question "The data collected will be used exclusively for the declared purpose and not for any other unreported or incompatible with the legitimacy of its use (principle of purpose limitation)" is answered affirmatively. There is no justification for how this principle is fulfilled.

It is stated in the Results section that "After analyzing the necessity and proportionality of this processing, the risk analysis carried out, and the assessment of the Residual risk after applying the corresponding measures..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/51

security measures, the result of this Data Protection Impact Assessment (DPIA) study is:

ACCEPTABLE."

14.

An informational sign has been installed next to the time registration device regarding data processing, ensuring it is clearly visible to all employees. Additionally, the information on data protection related to the use of fingerprinting for work hour control has been expanded and communicated to employees through the Employee Portal.

15.

In response to this complaint, an email has been sent to all employees with the informational clause.

16.

The following measures have been implemented to prevent similar incidents from occurring:

- Informational sign next to the time registration device regarding data processing.

A copy of the informational sign is provided, which includes information about the data controller, purpose, legal basis, recipients, rights, and where to find additional information (Employee Portal).

A screenshot of the Employee Portal is provided, which includes a link to the informational clause, but does not include the publication date or URL of the Employee Portal.

- Expansion of the data protection information related to the use of fingerprinting for work hour control and communication to employees through the Employee Portal.

- Sending an email to employees with updated data protection information related to the use of fingerprinting for work hour control and as a channel for any questions or clarifications they may need.

- Follow-up will be conducted on the receipt of the new clauses published by all employees.

1.

A record of processing activities for fingerprinting is provided, indicating that fingerprinting is used as a

verification/authentication system, not for identification.

2.

Other systems have been discarded, e.g., card-based time registration, because past experiences led to conflicting situations. This is a service with high staff turnover. When the card system was used for time registration, it was sometimes lent to other individuals who were not the cardholders, resulting in the presence of unauthorized personnel in the work area, with all the associated labor security risks. The use of fingerprinting is the system that prevents these criminal situations and ensures compliance with labor regulations and prevents unauthorized access.

THIRD:

On May 14, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH:

The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

BACKGROUND

Along with the complaint, the complainant provides the following emails:

- A copy of an email sent by soliobrera.secciontourline@gmail.com to ***USER.1@grupoctc.com and ***USER.2@grupoctc.com dated 01/31/2022 with the text:

"Last Friday, when I was about to sign out of my workday (a method implemented from the beginning for the registration and control of entry-exit of workers at the Madrid-Coslada work center), I was informed that we would start using fingerprint access control and that they needed to take my samples, to which I asked if they were going to provide me with information and some document in which I consent to the processing of this type of data, and they told me (to my surprise) that there is none[...]"

- A copy of an email sent by ***USER.1@grupoctc.com dated 02/02/2022 with the text:

"First of all, they did not properly inform you when you asked in the service if there was information about the processing of the data, as we do have such information. Specifically, it is available on the CTC employee portal, which you have access to since you joined the company.

On the other hand, and regarding Article 9 on the Lawfulness of Processing, explicit consent is not necessary because the processing is necessary for the fulfillment of obligations by the employer, as well as for the exercise of the rights of the data controller.

It is true that Article 13 provides for a duty of information, and this duty is fully complied with as the information is posted on the portal of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/51

Employee (in the data protection policy). There you will find all the information related to the data controller, purposes of data collection, recipients, data retention, and the procedure for exercising rights.

Secondly, you mention that Article 64.5.f) empowers you to issue a prior report. In this case, I regret to inform you that point 5 of the aforementioned article is related to work control (in a content sense). In fact, the wording of the article stipulates the following: "the implementation and review of systems for organizing and controlling work, time studies, establishment of bonuses and incentives, and job evaluation." In this case, it concerns a fingerprint timekeeping system, and the lawfulness of this processing is supported not only by Article 6 of the GDPR 2016/679 EU but also by compliance with a legal obligation such as time registration, regulated in Article 34.9 of the Workers' Statute.

For your peace of mind, I would like to mention that the fingerprint, in this case, does not acquire the category of special data because it is used solely to authenticate that the person is who they claim to be. Furthermore, the fingerprint is not stored; only a series of points that, via an algorithm, provide a

unique signature for that fingerprint is stored. That is to say, it does not represent the fingerprint by itself and is kept in a centralized system with restricted access.

Regarding the reason for this timekeeping system, it is the one being implemented in most CTC services, including headquarters.

Finally, if after this explanation you still consider it necessary, we will send you the results of the impact assessment study (EIPD) that you requested.

[...]

During the proceedings, the following entity was investigated:

CTC EXTERNALIZATION, S.L. with NIF B60924131, located at PLAZA EUROPA, 30-32, 08902 L'HOSPITALET DE LLOBREGAT (BARCELONA) (hereinafter CTC)

RESULT OF THE INVESTIGATION PROCEEDINGS

General issues:

1. That in the event that the employee declines to use their fingerprint for the marking process or the fingerprint is insufficiently good, marking can be done using an RFID card.
2. That the processing of fingerprints began on 29/12/2021 and ends when the employment relationship with the employee terminates. In that case, the hash of the fingerprint is deleted.
3. That there are 208 fingerprint readers installed in 117 workplaces, all in Spain.

Regarding the information on data protection provided:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/51

4. They provide screenshots showing that the document named "POL RGPD CTC EXTER_2021.pdf" was published on 28/10/2021 associated with a "cluster_id" = 66 which, they state, refers to the employees to whom the document is published.
5. They provide a screenshot from their systems showing "cluster_id" = 66 associated with the field "description" = "Employees of CTC society."
6. They provide a copy of an email sent to ctc@grupoctc.com on 28/10/2021 with the subject "Update on Data Protection Policies CTC EXTERNALIZATION S.L.U." where it states:

"[...]"

Through this communication, we would like to inform you that CTC EXTERNALIZATION S.L.U., in its obligation to comply with regulations, has proceeded to update its Data Protection Policies regarding the processing of personal data. You can access the publication of the new policies through the Employee Portal:

POL/RGPD CTC EXTER_2021: Data Protection Clause for Employees

You must read these clauses carefully and click to accept them. If you have any questions, you can contact the Data Protection Department via email: dpo@grupoctc.com

"[...]"

7. The informative clause referred to earlier is provided, which states as Date: 02/03/2018, Update Date: 26/10/2021, and the code "POL/RGPD CTC EXTER_2021." It also contains information about:

- a. The legal framework
- b. The data controller
- c. The legitimacy, which is the employment contractual relationship.
- d. Purposes of processing, which are to manage the employment relationship with employees, administrative accounting management, payroll preparation, occupational risk prevention, training. It is informed that a fingerprint reader is installed for access to offices.
- e. Recipients, where it states:

"The data will be communicated to public administrations (Social Security and Tax Agency) in compliance with labor regulations, labor mutuals, to the labor advisory company, to training companies, and to banking entities for the direct debit and payment of salaries.

Also among companies of the Group, to client companies to which we provide our services, as well as

to suppliers who act as data processors and with whom duly signed data protection contracts are in place.

In the case of subcontracting, the employee authorizes the transfer of the data included in the TC's to all those companies that are necessary to carry out the subcontracting.

If the Employee's task involves driving vehicles, the Employee's data will be transferred to the vehicle rental company, as well as to the Administration in the case of a fine for traffic violations."

f. Employee confidentiality obligation.

g. Data retention, where it states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/51

"The data provided will be retained for as long as the contractual relationship lasts and for the necessary years to fulfill legal obligations.

It is reminded that the use of the email account provided by the company is strictly limited to professional purposes and not for personal matters.

The Employee agrees to use email and the Internet only for professional work-related matters, expressly acknowledging that the email account is the property of the company.

It is also informed that the company, in the event of termination of employment, will have access to the corporate email and equipment used by the Former Employee."

h. Rights.

In that document "POL/RGPD CTC EXTER_2021" there is exclusively the following specific reference to the processing of fingerprints:

"[...]

A fingerprint reader is installed for access to offices.

[...]"

8. Screenshots of their systems are provided showing that the claimant accessed "(...)" on dates between 23/08/2021 and 16/12/2021. It is also noted that the claimant executed the action "sign" regarding the object "POL06 2018 CLAUSULA PROTECCION DATOS" on 23/08/2021 at 10:20. It is also noted that there is an "agreement_date" related to the claimant and the document "POL06_2018_CLAUSULA.pdf" on 23/08/2021 at 10:20:16. It is recorded that the last "agreement_date" associated with the claimant was on 23/08/2021.

9. A screenshot of the employee portal is provided where the "Informative clause on the use of fingerprints for monitoring working hours" and "Employee Data Protection Clause" are noted. There is a button to the right of each document with the text "Received," which, when pressed, marks the document as "Received."

10. After receiving the transfer of the complaint from the AEPD, they published the more detailed clause "Informative clause on the use of fingerprints for monitoring working hours," which was sent by email. An email sent on 22/03/2022 with this informative clause is provided. This informative clause contains specific information about the processing of fingerprints with sections on the responsible party, legitimacy, purpose, recipients, retention period, rights, and security measures. It is noted in this provided information, "This is an authentication/verification system, not an identification system."

Regarding the technical characteristics of the system and the contracts:

11. A single Windows Server 2016 server is used as a virtual machine managed by CTC. (...). The server is located in Spain. A signed and dated copy of the service contract dated 27/01/2023 between CTC and ***COMPANY.1) is provided, with the latter being the data processor. This contract states that CTC has contracted ***COMPANY.1 for the implementation and maintenance of the access control and working hours monitoring system using fingerprints.

It is also noted that there is another contract dated 29/09/2020 and signed between CTC and ***COMPANY.1 as the software provider for control and access and attendance (...). A contract with the hosting provider ***COMPANY.2 is provided, dated 27/11/2019. The object of the contract is not specified, nor is the complete contract provided. It is noted in section "12 Personal data" in subsection

"5) Data processing responsibility of the Client, ***COMPANY.2 as data processor" that:

"5) Data processing responsibility of the Client. ***COMPANY.2 as data processor

Only in the event that ***COMPANY.2 has access to personal data for which the Client is responsible, and the provision of the contracted services involves the processing of personal data on behalf of a data controller, whether the Client or a third party that contracts the Client's services directly or indirectly, ***COMPANY.2 will be considered a 'data processor,' committing to comply with the obligations that correspond to it based on the nature and scope of the contracted services and in accordance with the provisions of the current data protection regulations, national or supranational. [...]"

12. The fingerprint readers are (...). A document of technical specifications of the reader is provided, indicating that it supports (...).

13. The fingerprint reader is a device located in an accessible and transit area where employees register their different clock-ins throughout the workday. For this, they can use their fingerprint, and the system calculates the hash that will be compared with the one registered at the time of its activation in the system (registration of the initial fingerprint hash and association with the employee).

14. The system is configured to perform a 1:N fingerprint comparison. It (...) calculates the template and compares it with those stored. If there is a match with any stored pattern, the reading is considered valid. A diagram is provided showing that after detecting the finger on the sensor and calculating the pattern, there is a process of "Comparing with stored patterns."

15. The template is generated in the biometric module, so the fingerprint image is not stored or propagated to other systems. At no time is the employee's fingerprint stored. The response obtained by the module is the template. The biometric template is according to (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/51

16.

That the template is registered in the database. That a signal is sent to propagate the template only to the devices where the employee performs their work shift.

17.

That regarding how it is guaranteed that the captured fingerprint is deleted at the end of the capture process, it states the following:

"In no case is the image of the fingerprint stored as it is not obtained; the response obtained by the module is the template. All these procedures and criteria are based on the specific standard (...)."

The standard (...) is not provided.

18.

That in response to the requested information about the detailed step-by-step description of the complete process followed by an employee to access their workplace and clock in at the start of the workday using the fingerprint reading devices and, if applicable, without using them, CTC states:

"The fingerprint reader is a device located in an accessible and transit area where employees register their various clock-ins throughout the workday; for this, they can use their fingerprint, and the system calculates the hash that will be compared with the one recorded at the time of its activation in the system (registration of the initial fingerprint hash and association to the employee). Once the system recognizes the hash, an option for the type of clock-in is presented, e.g., entry, exit, or break; the clock-ins are synchronized with the central server through a private network. No additional information is collected. The employee may need other means to use the device (e.g., insufficiently good fingerprint reading) or decline the use of their fingerprint for the clock-in process; in both cases, they can do so using an RFID card."

Regarding the content of the database:

19.

It provides an extraction from its database where, for 100 records, the data (...) is noted. It is verified that the "code" is composed of numbers and letters. (...). In the extraction of this data, it is noted that

the fingerprint hash is in a different table from the table where the identifying data of the employees is located. However, it has not been possible to ascertain the possible security measures that may be implemented to separate access to both tables.

20.

It provides a screenshot of its systems where a total of ***CANTIDAD.1 fingerprints of employees are stored.

21.

It provides an extract from the database with all users who have been removed from the system with ***CANTIDAD.2 as well as another extract with the deletion dates of each fingerprint with ***CANTIDAD.3.

It is verified that the employee removal table has the ID field extracted from the user.id field, and the fingerprint deletion table has the USER_ID field. It is verified that by searching for matches by the ID and USER_ID fields, for ***CANTIDAD.4 employees, the removal date exactly matches the fingerprint deletion date. It is also verified that there are fingerprint deletions prior to the date 29/12/2021. In total, there are ***CANTIDAD.5 fingerprint deletions prior to 29/12/2021: Finally, it is verified that the first fingerprint deletion occurs on the date 25/03/2020.

22.

That regarding the deletion of fingerprints, it states that biometric templates are completely removed from the system in an automatic employee synchronization process (4 times a day). That since it is an automatic process, it guarantees that the objective of data deletion is fulfilled.

Regarding the impact assessment:

23.

That they justify compliance with data minimization, as well as the analysis of necessity and proportionality and the process followed to ensure that the data collected is not used for another purpose, stating the following:

"We justify the application of the principle of minimization, in the sense that in each of the operations that constitute the processing, the data and operations are the minimum and necessary to address the purposes of the processing. To carry out the clock-in queries, it is necessary to have the fingerprint hash associated with the code and in relation to the employee's name and surname; otherwise, there is no way to know to whom the work shift corresponds. On the other hand, regarding the purpose of access control associated with occupational risk prevention issues, in the event of an emergency (e.g., fire, ...), it is necessary to know which people are inside the facility.

Regarding the weighting of the proportionality of the processing, considering the following criteria:

Judgment of suitability: to achieve the objective of access control and work shift management, the system through the fingerprint hash has proven to be adequate for the intended purpose. The effectiveness threshold that should be reached to comply with the purposes of the processing must be practically 100%; it is about fulfilling a legal obligation and ensuring safety in the workplace. We believe that the effectiveness of this system helps us reach this threshold.

Judgment of necessity: The correct management of the work shift, as well as access control to the service, is relevant, and to achieve the intended purpose, this system offers us greater reliability compared to others. Other systems had been used, e.g., clocking in with a card, but after the experience with it, it did not provide us with sufficient effectiveness for the intended objective. Using the card system for clocking in, we experienced that, on certain occasions, the card was lent to another person who was not the cardholder, with all the risks that this entails for workplace safety and the inaccuracy of the work shift record.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/51

We consider that there is no alternative treatment that is equally effective for achieving the intended purpose, taking into account the facilitation of system use for the employee, the accuracy of records, and workplace safety.

Strict proportionality assessment: When we conducted the initial evaluation of implementing this system, we considered that the severity of the risk to the rights and freedoms of employees and the intrusion into their privacy was negligible. The fingerprints of employees are not stored, nor can they be reproduced from the hashes.

On the other hand, weighing the social benefit for employees, we assessed that it was more positive and convenient for them, avoiding situations, e.g., where a card is lost or forgotten in the vehicle, resulting in delays in clocking in, which primarily affects the employees themselves.

Regarding Expiry: the processing ceases at the moment the employment relationship with the employee is suspended. The hashes are deleted.

Regarding use for other purposes: The only function that the system allows with the use of the fingerprint is the registration of clocking in and/or access to the center; it does not enable any other access to employee data, nor is it used as part of identification for other systems or functionalities.

In relation to access to readers, application server, and database server, and security in general:

24. Access to the readers cannot be made directly but only through the application or by accessing the web embedded in the device, with unique administrative credentials. Access to the readers cannot be made from any other point on the network other than from the server, as network restrictions are in place.

25. The application server is isolated from the domain. It only has 3 access users: "CLI.gruntc", "CLI.**COMPANY.1", "PRV.gruntc". It provides access logs to said server where successful authentication is recorded exclusively for two of those users.

26. It provides access logs to the database server where users "Account Name" access is recorded, for which no data has been provided, such as "DWM-12", "SRVINTEMOS" or "-".

27. It provides access logs to the application that controls the system as well as the users with access permissions to this application and the deleted users. These lists include accesses to the application by users "CTT", "CTT Valencia", "Gestamp", "...", "Makro", which do not appear in the list of users with access permission to the application nor in the list of deleted users.

28. It provides documents of the Access Procedure to servers and applications, as well as the Procedure for adding and removing system users.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/51

29. In response to the request for justification of why it cannot do without the direct association between the fingerprint hash and the name and surname, they state:

"The fingerprint hash is related to an employee code that could be sufficient to complete the work record, but clearly insufficient to allow real-time tracking of clocking in by the center's managers. Likewise, it would not allow control over the location of individuals (inside-outside) for occupational risk prevention purposes.

It is noteworthy that the device module, when comparing the hash in real-time, returns the code. And it is from this code that all functionalities are performed; the hash does not intervene in any way in the process."

30. In response to how it ensures that fingerprint data is not reused for other purposes or by other responsible parties, they state:

"Biometric devices are inventoried with their corresponding installation data, location, and status. Devices withdrawn due to closure are recovered, with the content deleted and stored for later use. Biometric data has no meaning in the installation; it does not provide interpretable or relevant information. The use of biometric data is also completely ruled out for any other use; its use as identification does not provide us with value beyond the agile collection of clocking in, which is easy for the employee and helps avoid fraudulent clocking in. The hardware is dedicated and cannot be used for any purpose other than what the manufacturer designed."

CONCLUSIONS OF THE PREVIOUS INVESTIGATION REPORT

1. There are clear indications that the user accessed a URL that could be that of the employee portal, but such evidence is not recorded. It is noted that the complainant accepted the data protection information document, but did so on a date prior to the last update of the information document. In this last update of the document, there is specific information regarding the processing of fingerprints, although it only mentions this processing with one phrase.
2. An email sent in October 2021 to the organization with the updated data protection information document is recorded.
3. Another email was sent, although in March 2022, with more specific information regarding the processing of fingerprints.
4. Regarding the operation of the system, it operates with a 1:N fingerprint comparison; however, the data protection information provided states that it is an authentication system, not an identification system.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/51

5. Regarding the deletion of fingerprints, there are hashes of deleted fingerprints dated prior to the first transmission of information regarding data protection with information on the processing of fingerprints and also prior to the date on which they state that processing began.

6. Regarding the security of the system:

- a. Identifying data of the employee and their fingerprint hash are stored and related. CTC has not been required to justify the security measures implemented to prevent any unwanted association of this data, although they have been asked to justify why they need the direct association between the identifying data and the fingerprint hash, to which the response seems insufficient.

- b. The information provided by CTC shows access by some users who are not listed in the provided privileged access user lists, both to the application and to the database server.

- c. CTC has not demonstrated how the deletion of the fingerprint is guaranteed after its capture.

FIFTH:

On May 12, 2023, the Director of the Spanish Data Protection Agency agreed to initiate sanctioning proceedings against the accused party for the alleged infringement of Article 35 of the GDPR, Article 32 of the GDPR, and Article 13 of the GDPR, classified under Articles 83.5 of the GDPR and Article 83.4 of the GDPR.

SIXTH:

After notifying the aforementioned initiation agreement in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the accused party submitted a written statement of allegations in which, in summary, they state the following:

Regarding the accusation under Article 13 of the GDPR for the lack of information to workers concerning the implementation of a timekeeping system through the processing of biometric data, the accused party limits itself to reaffirming arguments already presented in the preliminary investigation phase: (having corrected the informative clause; the complainant would have accessed the informative content of the clause; the adoption of additional and subsequent informative measures; and the existence of alternative systems to fingerprinting for timekeeping).

Regarding the violation of Article 32, they argue that the fingerprint is not stored. What the system does is convert the fingerprint into a numerical identifier; and it has already been demonstrated that users who should not have access to the data were deactivated, and thus could not access the application.

Finally, nothing was alleged regarding the non-compliance with Article 35 of the GDPR, related to the absence of a genuine impact assessment.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

16/51

SEVENTH:

On November 2, 2023, a resolution proposal was made, proposing

“FIRST That the Director of the Spanish Data Protection Agency sanctions CTC EXTERNALIZACIÓN, S.L., with NIF B60924131,

- For an infringement of Article 13 of the GDPR, classified under Article 83.5 of the GDPR, with a fine of €200,000 (TWO HUNDRED THOUSAND EUROS).
- For an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of €100,000 (ONE HUNDRED THOUSAND EUROS).
- For an infringement of Article 35 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of €100,000.00 (ONE HUNDRED THOUSAND EUROS).

SECOND That the Director of the Spanish Data Protection Agency orders CTC EXTERNALIZACIÓN, S.L., with NIF B60924131, that pursuant to Article 58.2.d) of the GDPR, within a period of 6 months, demonstrate compliance with the following measures:

- Inform all workers adequately, including all aspects that have not been included so far, as detailed in the legal grounds of this proposal.
- Establish the necessary security measures to prevent access by personnel not expressly authorized, as well as to ensure the deletion of the fingerprint after its capture. Also, to separate access to the tables containing the hashes of the fingerprints and the identifying data of the workers.
- Prepare a data protection impact assessment that includes all aspects provided for in Article 35 of the GDPR, particularly taking into account the defects noted in this proposal.”

EIGHTH:

After notifying the aforementioned resolution proposal in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the accused party submitted a written statement of allegations in which, in summary, they state the following:

Regarding the accusation under Article 13 of the GDPR: in this regard, the accused limits itself to reiterating allegations already presented in the initiation agreement:

- They reiterate that CTC made corrections to the initial version of the data protection clause (dated October 2021) for adequate information to workers.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/51

- In the event that any harm has been caused, the rights of the potential affected parties would have been fully guaranteed through the application of the subsequent informative measures adopted by CTC.
- The information regarding the processing of personal data related to the fingerprint of CTC employees would have been available prior to the implementation, which took place in December 2021.
- CTC established an informative poster next to the timekeeping devices and also sent an informative email.
- In any case, there would not have been a total lack of information, but rather aspects that would need clarification.

In relation to the allegation under Article 32 of the GDPR:

- It reiterates what has already been claimed during the investigation phase, regarding having identified the companies involved in the establishment of the system and having provided documents about the technology used.
- It indicates that at the time, a responsible declaration from the company INTEMO was provided, certifying that the fingerprint is not stored.
- As a new point compared to previous allegations, CTC provides a report on user registrations in the system.
- Access to the system, it claims, would only be carried out by "technical users for the purpose of controlling" the system.

In relation to the allegation under Article 35 of the GDPR:

- CTC reproduces what it considers to be the reproach directed at it in the file, which would only be, in its opinion, that the impact assessment document provided by the respondent would not constitute an "impact assessment" in the terms of the GDPR, as it suffers from substantial defects such as not determining the purpose of the processing or not containing a judgment regarding the necessity and proportionality of the system.
- It invokes various precedents from resolutions of this AEPD:
 - o E/00793/2016: the respondent interprets this resolution in the sense that if workers have been informed about the implementation of the system, the AEPD would not assess its suitability.
 - o E/10900/2019: according to this resolution, the biometric access system can be implemented if there is a legal basis, even without the consent of workers.
 - o E/03925/2020. The AEPD, in the opinion of the respondent, would be accepting a "similar" case in which there would be no impact assessment.
- In relation to the principle of proportionality, it argues that in the previous file PS/00050/2021, a fine of €20,000 was imposed for the infringement of lacking an impact assessment, whereas in this case, a sanction of €100,000 would be applied.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es

18/51

From the actions carried out in the present procedure and from the documentation in the file, the following has been established:

PROVEN FACTS

FIRST.

A.A.A. (hereinafter, the claimant) submitted a complaint to the Spanish Data Protection Agency on February 14, 2022. The complaint is directed against CTC EXTERNALIZACIÓN, S.L. with NIF B60924131. The reasons on which the complaint is based are as follows:

It is claimed that in the entity CTC EXTERNALIZACIÓN, S.L., biometric data, specifically fingerprints, have been requested from employees for the purpose of implementing a timekeeping system based on that data.

It is stated that at the time of collecting the biometric data, it was not communicated that the information was available on the employee portal, located in the most remote part of the application to which not all workers using the new timekeeping system have access.

SECOND.

An email was sent to ctc@grupoctc.com on 28/10/2021 with the subject "Update Data Protection Policies CTC EXTERNALIZACIÓN S.L.U." which states:

"[...]"

Through this communication, we would like to inform you that CTC EXTERNALIZACIÓN S.L.U., in its obligation to comply with regulations, has proceeded to update its Data Protection Policies regarding the processing of personal data. You can access the publication of the new policies through the Employee Portal:

POL/RGPD CTC EXTER_2021: Employee Data Protection Clause

You must read these clauses carefully and click to accept them. If you have any questions, you can contact the Data Protection Department via email: dpo@grupoctc.com [...]"

THIRD.

CTC provides an informative clause which states the Date: 02/03/2018, Update Date: 26/10/2021, and the code "POL/RGPD CTC EXTER_2021". This document contains exclusively the following specific reference to the processing of fingerprints:

"[...]"

A fingerprint reader is installed for access to offices.

"[...]"

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/51

FOURTH.

Screenshots from the CTC systems show that the claimant accessed an application coded as "com.ctc.portal[...]" on dates between 23/08/2021 and 16/12/2021. It is also recorded that the claimant executed the action "sign" regarding the object "POL06 2018 CLAUSULA PROTECCION DATOS" on 23/08/2021 at 10:20. It is further noted that there is an "agreement_date" related to the claimant and the document "POL06_2018_CLAUSULA.pdf" on 23/08/2021 at 10:20:16. It is recorded that the last "agreement_date" associated with the claimant was on 23/08/2021.

FIFTH.

After receiving the transfer of the claim from the AEPD, CTC published a more detailed informative clause "Informative clause on the use of fingerprint for labor control," which was sent via email.

An email sent on 22/03/2022 with this informative clause is provided. This informative clause contains specific information about the processing of fingerprints, including sections on the responsible party, legitimacy, purpose, recipients, retention period, rights, and security measures. It is stated in this provided information, "This is an authentication/verification system, not an identification system."

SIXTH.

The fingerprint reader is a device located in an accessible and transit area where employees register their different clock-ins throughout the workday. For this, they can use their fingerprint, and the system calculates the hash that will be compared with the one registered at the time of activation in the system (registration of the initial fingerprint hash and association with the employee).

The system is configured to perform a 1:N fingerprint comparison. It has the biometric module CBM that calculates the template and compares it with those stored. If there is a match with any stored pattern, the reading is considered valid.

SEVENTH.

The responding party provides an extraction from its database where, for 100 records, the data of name, surname, user ID, code, date of registration, date of termination, and fingerprint hash are recorded. It is verified that the "code" consists of numbers and letters. It is verified that the letter complies with the rule (...). In the extraction of this data, it is noted that the fingerprint hash is in a different table from the table where the identifying data of the employees are located. However, it has not been possible to ascertain the possible security measures that may be implemented to separate access to both tables.

EIGHTH.

In the CTC systems, a total of ***CANTIDAD.1 fingerprints of employees are stored. CTC provides an extract from the database with all users who have been terminated from the system with ***CANTIDAD.2 as well as another extract with the deletion dates of each fingerprint with ***CANTIDAD.3.

It is verified that the employee termination table has the ID field extracted from the user.id field and the

fingerprint deletion table has the USER_ID field. It is verified that by searching for matches by the ID and USER_ID fields, for ***CANTIDAD.4 employees, the termination date exactly matches the fingerprint deletion date.

It is also verified that there are fingerprint deletions prior to the date 29/12/2021. In total, there are ***CANTIDAD.5 fingerprint deletions prior to 29/12/2021. Finally, it is verified that the first fingerprint deletion occurs on the date 25/03/2020.

NINTH.

The readers cannot be accessed directly but only through the application or by accessing the web embedded in the device, with unique administrative credentials. Access to the readers cannot be made from any other point on the network other than from the server, as network restrictions are implemented.

TENTH.

The application server is isolated from the domain and has only 3 access users: "CLI.gruntc", "CLI.***EMPRESA.1", "PRV.gruntc". CTC provides access logs to this server where successful authentication is recorded for only two of those users.

ELEVENTH.

The impact assessment document provided by CTC contains the following:

"We justify the application of the principle of minimization, in the sense that in each of the operations constituting the processing, the data and operations are the minimum and necessary to address the purposes of the processing. To carry out the clock-in queries, it is necessary to have the hash of the fingerprint associated with the code and in relation to the name and surname of the Employee; otherwise, there is no way to know to whom the workday corresponds. On the other hand, regarding the purpose of access control associated with occupational risk prevention issues, in the event of an emergency (e.g., fire, ...), it is necessary to know which individuals are inside the facility.

Regarding the assessment of the proportionality of the processing, considering the following criteria: Suitability judgment: to achieve the objective of access control and workday management, the system through the fingerprint hash has proven to be adequate for the intended purpose. The effectiveness threshold that should be reached to comply with the purposes of the processing must be practically 100%; it is about fulfilling a legal obligation and ensuring safety in the workplace. We believe that the effectiveness of this system helps us reach this threshold.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/51

Necessity Judgment: The proper control of working hours, as well as access control to the service, is relevant and to achieve the intended purpose, this system offers us greater reliability compared to others. Other systems had been used, e.g., card punching, but after the experience with it, it did not provide us with sufficient effectiveness for the intended objective. By using the card system for punching, we experienced that, on certain occasions, the card was handed over to another person who was not the cardholder, with all the risks that this entails for workplace safety and the inaccuracy of the working hours record. We believe that there is no alternative treatment that is equally effective for achieving the intended purpose, taking into account the facilitation of system use for the employee, the accuracy of records, and workplace safety.

Strict Proportionality Judgment: When we conducted the initial assessment of implementing this system, we considered that the severity of the risk to the rights and freedoms of employees and the intrusion into their privacy was negligible. The fingerprints of the employees are not stored, nor can they be reproduced from the hashes.

On the other hand, weighing the social benefit for employees, we assessed that it was more positive and convenient for them, avoiding situations such as losing the card or forgetting it in the vehicle, which causes delays in punching that most adversely affect the individuals concerned.

Regarding Expiry: The treatment ceases at the moment the employment relationship with the employee is suspended. The hashes are deleted.

Regarding use for other purposes: The only function that the system allows with the use of the fingerprint is the recording of punching and/or access to the center; it does not enable any other access to employee data, nor is it used as part of identification for other systems or functionalities.

LEGAL GROUNDS

I Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/51

II Preliminary Issues

In the present case, in accordance with the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that CTC EXTERNALIZACIÓN, S.L. carries out this activity in its capacity as data controller, as it is the entity that determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR: "Data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if Union or Member State law provides otherwise.

According to the data obtained from AXESOR, the turnover of the respondent for the fiscal year 2020 was (...).

Additionally, Article 4.2 of the Regulation defines the "processing" of personal data as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of making available, comparison or interconnection, restriction, erasure, or destruction."

In this regard, it is pertinent to refer to the distinction made by the data subject in their allegations regarding the difference between "identification" and "authentication" in relation to the processing of biometric data. They assert that a system of "identification" (i.e., one that determines the identity of the subject based on their fingerprint) is not being used, but rather one of "authentication" (i.e., one that verifies that the fingerprint corresponds to the one previously provided).

In this respect, two points must be emphasized. Firstly, it is highly questionable whether the system used in this case is one of "authentication." The installed fingerprint readers do not compare the subject's fingerprint with any document or medium that the subject uses at the time of registration; rather, they compare the fingerprint read at the time of registration with the total number of fingerprints previously registered by the employees. Thus, the comparison is 1:N.

However, the most important point is that, as early as the Guidelines 05/2022 from the EDPB on Facial Recognition Technologies, it is made clear that both systems (identification and authentication) constitute processing of special categories of personal data. Indeed, paragraph 12 of the Guidelines states the following:

(12) While both functions – authentication and identification – are distinct, they both relate to the processing of biometric data related to an identified or identifiable natural person and therefore constitute a processing of personal data, and more specifically a processing of special categories of personal data.

(12)

While both functions – authentication and identification – are distinct, they both refer to the processing

of biometric data related to an identified or identifiable person, and thus constitute a processing of special categories of personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/51

personal data, and more specifically the processing of special categories of personal data. (the translation is ours)

From the above, it follows that the regime provided for in the GDPR for special categories of personal data is applicable to the present case.

III Response to the allegations regarding non-compliance with Article 13 GDPR

In response to the allegations presented by the defendant entity both to the initiation agreement and to the proposed resolution, the following should be noted:

Regarding the accusation under Article 13 of the GDPR for the lack of information to workers concerning the implementation of a timekeeping system through the processing of biometric data, the defendant reiterates arguments already presented during the preliminary investigation phase:

- The fact that the information clause to workers has been corrected. In this regard, CTC expressly acknowledges having made the correction after receiving the complaint through this Agency.
- The claimant would have accessed the informative content of the clause.
- The adoption of additional and subsequent informative measures. Also, having placed informative posters next to the timekeeping devices.
- The existence of alternative systems to fingerprinting for employee timekeeping, particularly through the use of an RFID card.

In the case at hand, it has been demonstrated that the defendant did not properly inform about the processing. The informative clause referred to, which was included in the company's "employee portal" in October 2021, suffers from significant defects. These are further corroborated by the amendment made to the version of the informative clause, undated, but prepared after the information request from this Agency and, as stated in the preliminary investigation report, sent to the workers in March 2022:

- It does not include which processing is subject to said informative clause. In fact, the only specific reference to the processing of the fingerprint comes from a very brief mention in section 3: "A fingerprint reader is installed for access to offices." It does not indicate whether it is activated or if it collects the fingerprint and, of course, does not include the fingerprint data among those subject to processing.

On the contrary, the subsequent clause (March 2022) contains a specific reference to the processing of the "fingerprint for work time control."

In this regard, it is important to note that the informative clause seems to refer to a plurality of processing activities, which it encompasses in a single document drafted in a very brief manner. The processing activities carried out are not listed, and for all of them, a legitimizing basis is applied, which would be the execution of the contract. Furthermore, it states that the processing of personal data is carried out for multiple purposes:

- o Manage the employment relationship with the company's employees.
- o Administrative accounting management of employee data.
- o Payroll preparation.
- o Occupational risk prevention.
- o Training.

- In the first informative clause, joint information was provided for what were supposed to be multiple processing activities of personal data carried out by the company. Well, for all of them, the original document simply informed that the legitimizing basis was the expression "Labor contractual relationship."

However, in the subsequent version, this has been corrected, and referring specifically to the

processing of the fingerprint, it states that the legitimization would come from "compliance with a legal obligation (Article 34.9 of the Workers' Statute), concerning work time control."

As can be seen, a completely different legitimizing basis.

In fact, upon consulting the Record of Processing Activities provided by the defendant, in the processing "Access control and work time through fingerprint," the field "Legitimization of the processing operations" states "compliance with a legal obligation (Article 34.9 of the Workers' Statute)."

For all these reasons, the duty to inform workers was not fulfilled in this aspect in the initial information provided. In this regard, it should be recalled that the aforementioned Article 13.2.e) of the GDPR establishes that it must be informed whether "the communication of personal data is a legal or contractual requirement, or a necessary requirement to enter into a contract, and whether the data subject is obliged to provide the personal data and is informed of the possible consequences of not providing such data."

- Regarding the data retention period, the initial version of the informative clause stated, "The data provided will be retained as long as the contractual relationship lasts and for the necessary years to comply with legal obligations." This, as indicated above, in relation to the multiple processing activities that were carried out. However, in the subsequent version, it clarifies what the retention and blocking periods are, specifying the total period in years: "The data will be retained as long as the employment relationship lasts. The data regarding work time will be retained blocked and pseudonymized for the time required by legal compliance (4 years)."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/51

-

Neither in the initial version of the clause nor in the subsequent one is there any information regarding the right to lodge a complaint with the supervisory authority (art. 13.2.d) of the GDPR).

Regarding the alleged voluntary nature of the use of the fingerprint timekeeping system, it should be noted that it is not the purpose of this file to determine whether or not the workers were obliged to use that system. Regardless of the legitimacy concerning the processing of personal data or the possible obligation regarding its provision, it was the responsibility of the data controller to comply with its information duties established in Article 13 of the GDPR.

For all these reasons, it cannot be considered that the respondent has fulfilled its information obligations under Article 13 of the GDPR. It is also noteworthy that the text of the email sent by the company makes only a reference to the "update of its data protection policies," with no mention of the implementation of a fingerprint timekeeping system (which would surely have encouraged the consultation of the informative clause that, as has been seen, was completely defective).

IV Response to the allegations regarding the breach of Article 32 GDPR

Regarding this infringement, related to the lack of security measures in the processing of biometric data, CTC alleges the following:

Firstly, concerning the processing of the fingerprint data, it is claimed that the fingerprint image is not stored. What the system does is convert the fingerprint into a numerical identifier. Thus, when the worker clocks in, that identifier is compared with the one previously assigned to that fingerprint. Therefore, the fingerprint could not be reproduced from that numerical identifier. In this regard, it provides a certificate from the company IDEMIA IDENTITY & SECURITY FRANCE SAS stating that "there is no way to recover the templates in case of theft, as it is impossible to recreate an image of a fingerprint from the typical points."

Regarding this allegation, it should be noted that the attribution of the infringement of Article 32 is not based on the factor alleged by the respondent, but on what is reflected in the initiation agreement, namely:

"b. In the information provided by CTC, it is noted that some users who do not appear in the lists of

users with access privileges provided have accessed both the application and the database server.

c. CTC has not demonstrated how the deletion of the fingerprint after its capture is guaranteed.

d. As detailed in the preliminary investigation report, it is noted that the hash of the fingerprint is in a different table from the table where the identifying data of the employees are located. However, it has not been possible to ascertain the possible security measures that may be in place to separate access to both tables."

Regarding access to the application that controls the system, from which this Agency has deduced that access could occur by users who did not have permissions for it, it is claimed in the allegations that the documents provided during the inspection period would have already demonstrated that those users were deactivated, and therefore could not access the application. Furthermore, they indicate that they also provided their security and information policies.

As for the issue of access by users who would not have permissions, the following can be noted, after analyzing the documentation provided by the interested party in their allegations to the initiation agreement.

- It is confirmed that the users "CTT," "CTT Valencia," "Gestamp," "..." and "Makro" are indeed deactivated, as CTC claims. Therefore, it cannot be asserted that unauthorized access occurred regarding those users.

- Regarding the user "DWM-12," it appears in a screenshot provided by the interested party, with the header "Log File Viewer – SRVINTEMO" but does NOT appear in the file they refer to as "21.a.3 AccesosSQLSERVER.log." Thus, it is possible that this user is logged on the server log but NOT on the database log. Therefore, the explanation provided regarding it being an account that is automatically generated when a remote desktop session is initiated could be valid, and it could be deduced that it does not necessarily have to be an account that is actually accessing the database.

- On the other hand, the users "SRVINTEMO\$" or "-" do appear in the file named "21.a.3 AccesosSQLSERVER.log," which is where access to the database server is supposed to be recorded, and they also appear associated with the message "An account was successfully logged on." These users had not been identified in the response to the inspection license request. In any case, the allegations do not explain the matter with sufficient detail and clarity. They only include a somewhat ambiguous phrase about the nature of the user ("In the case of users for whom no data has been provided, such as "SRVINTEMO\$" or "-", they are not user or system accounts; they are simply information that appears in the log generated by the operating system itself.")

No evidence is provided in this regard, such as a list of users who are registered with access to the database or confirmation that the file "21.a.3 AccesosSQLSERVER.log" refers to database access logs.

Subsequently, in their allegations to the proposed resolution, the respondent has provided a technical report regarding access and users. From this, the following conclusions can be drawn:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/51

The respondent claims that, in response to the Inspection's request, what was attached was an extraction from the Windows event log that included all accesses. It is understood that what they provided in response to the request was not the specific accesses to SQL Server, although they did identify it as such at the time. Furthermore, it seems that the information provided in response to the request was cut off as it was a screenshot, and in this report, it would have been provided in a more complete manner.

Well, from the entirety of the documentation provided throughout the file (regarding the users "DWM-12", "-", "SRVINTEMO\$" concerning which it was not clearly determined who they were, it seems, according to the explanation given in allegations and associated with screenshots now provided, that they are linked with accesses from the user "CLI.gruntc", which has been previously declared as authorized for access.

Additionally, some specific accesses to SQL Server are also attached, and in these, accesses from the

users "sa", "SRVINTEMO\$", and "SQLTELEMETRY" are seen. The users are declared, according to the screenshot now provided, except for the account "SRVINTEMO\$". However, regarding this account "SRVINTEMO\$", it can be presumed that something similar will occur to what has already been explained regarding the other server log provided, where it could be seen that this same account was indeed linked to a user that was declared.

Therefore, after analyzing all the information and documentation now provided, it cannot be determined with total certainty the access of some users who do not appear in the lists of users with access privileges provided, both to the application and to the database server. As will be seen later, this factor is taken into account for the reduction of the amount of the sanction for the violation of Article 32.

Finally, it is necessary to state that nothing has been alleged regarding the rest of the facts attributed that were contained in the initiation agreement of this file. In this regard, we recall that the following was indicated:

"c. CTC has not demonstrated how the deletion of the trace after its capture is guaranteed.

d. As detailed in the report of prior investigative actions, in the extraction of the data, it is noted that the hash of the trace is found in a different table from the table where the identifying data of the employees are located. However, it has not been possible to ascertain the possible security measures that may have been implemented to separate access to both tables."

V Response to the allegations regarding the violation of Article 35 of the GDPR

In relation to this violation, CTC alleges the following: first, it invokes various precedents from resolutions of this AEPD:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/51

- E/00793/2016: the respondent interprets this resolution in the sense that, if workers have been informed about the implementation of the system, the AEPD would not evaluate its suitability.

In relation to this assumption, it should be emphasized that it judges a case that occurred before the entry into force of the current GDPR. And in this Regulation, two obligations are perfectly established and differentiated. On the one hand, the information to the holders of personal data about the data that will be processed and its conditions (art. 13). And on the other, the need to overcome an impact assessment related to data protection, which includes "an assessment of the necessity and proportionality of the processing operations concerning their purpose" (art. 35.7.b).

In any case, it cannot be asserted that mere information to workers could be a legitimizing basis for the installation of the biometric system. And all this without prejudice to the fact that in the present file, there is also a sanction for the absence of information, so that even that requirement, which they indicate would be sufficient, would not have been met.

- E/10900/2019: according to this resolution, it is alleged that the biometric access system could be implemented if there is a legal basis, even without the consent of workers.

In this regard, it is noted that Article 6.1 of the GDPR establishes what the different legitimizing bases for the processing of personal data are. Consent (letter a) of that article) is only one of them, and other bases such as the execution of a contract, compliance with a legal obligation, or even the existence of a legitimate interest that must be weighed can effectively occur. And furthermore, for the processing of special categories of personal data, it is required that an exception from paragraph 2 of Article 9 of the GDPR occurs.

However, the concurrence of an exception from Article 9.2 of the GDPR along with a legitimizing basis from Article 6 of the GDPR in no way exempts compliance with the rest of the obligations established by the GDPR. And one of them consists of the preparation and overcoming of a data protection impact assessment in the cases established in that Regulation, among which is the processing that is the subject of this file.

Thus, it cannot be asserted that the mere existence of a legitimizing basis exempts the necessary

realization and overcoming of the data protection impact assessment in the legally provided cases. Moreover, the resolution that concludes this file bases its motivation on the old differentiation, for the purposes of determining the processing of special categories of personal data, between "identification" and "authentication" for the determination of identity in fingerprint timekeeping systems.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/51

As has been sufficiently explained in the second ground of this resolution, based on the Guidelines 05/2022 of the EDPB regarding facial recognition, the distinction between both types of processing has disappeared, considering in any case the existence of a processing of special categories of personal data.

-

E/03925/2020. The AEPD, in the opinion of the respondent, would be accepting a supposed "similar" case in which there would be no DPIA.

Analyzing the invoked procedure, it is observed that it is a resolution of the archiving of proceedings, in which the aforementioned archiving was due to the fact that the data protection impact assessment had indeed been prepared and passed. Thus, the resolution states the following:

"The respondent has provided a copy of the extensive Impact Assessment carried out for the processing of the digital footprint.

Therefore, it has been demonstrated that the actions of the respondent, as the entity responsible for the processing, have been in accordance with the regulations on personal data protection analyzed in the previous paragraphs."

Consequently, this case, in which the impact assessment was indeed prepared and passed, has nothing to do with the one being judged in the present file.

In relation to the principle of proportionality, the respondent alleges that in the file of this Agency PS/00050/2021, a fine of €20,000 was imposed for the infringement of lack of impact assessment, while in this case, a sanction of €100,000 would be imposed.

It should be noted in this regard that Article 83.4 of the GDPR establishes that the amount of the sanction will take into account the turnover of the respondent. In this respect, as reflected in this resolution, it has been confirmed that the turnover of the respondent party is (...). while the revenues of the sanctioned party in PS/00050/2021 were considerably lower. Furthermore, the other circumstances taken into account for the graduation of the sanction are different in both cases.

Additionally, it should be noted that according to what is established in Article 83.1 of the GDPR, the supervisory authorities shall ensure that the imposition of administrative fines under this Regulation is effective, proportionate, and dissuasive in each individual case.

Its paragraph 2 adds that "Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/51

VI Unfulfilled information obligation. Article 13 GDPR

Article 13 of the GDPR establishes the following:

Information to be provided when personal data is obtained from the data subject

1. When personal data relating to a data subject is obtained from the data subject, the data controller shall provide the data subject with all the information indicated below at the time the data is obtained:

a) the identity and contact details of the controller and, where applicable, of its representative;

- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;
- e) the recipients or categories of recipients of the personal data, where applicable;
- f) where applicable, the intention of the controller to transfer personal data to a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49, paragraph 1, second subparagraph, reference to the appropriate or suitable safeguards and the means to obtain a copy of these or the place where they have been made available.

2. In addition to the information mentioned in paragraph 1, the data controller shall provide the data subject, at the time the personal data is obtained, with the following information necessary to ensure fair and transparent data processing:

- a) the period for which the personal data will be stored or, when that is not possible, the criteria used to determine that period;
- b) the existence of the right to request from the controller access to personal data relating to the data subject, and their rectification or erasure, or the restriction of processing, or to object to the processing, as well as the right to data portability;
- c) when the processing is based on Article 6, paragraph 1, letter a), or Article 9, paragraph 2, letter a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the processing based on the consent prior to its withdrawal;
- d) the right to lodge a complaint with a supervisory authority;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/51

- e) if the communication of personal data is a legal or contractual requirement, or a necessary requirement to enter into a contract, and if the data subject is obliged to provide the personal data and is informed of the possible consequences of not providing such data;
- f) the existence of automated decisions, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, significant information about the logic applied, as well as the importance and the expected consequences of such processing for the data subject.

3. When the data controller intends to process personal data for a purpose other than that for which it was collected, it shall provide the data subject, prior to such further processing, information about that other purpose and any additional relevant information pursuant to paragraph 2.

4. The provisions of paragraphs 1, 2, and 3 shall not apply when and to the extent that the data subject already has the information.

In this regard, Recital 60 of the GDPR states that “The principles of lawful and transparent processing require that the data subject be informed of the existence of the processing operation and its purposes. The data controller must provide the data subject with any additional information necessary to ensure lawful and transparent processing, taking into account the specific circumstances and context in which the personal data are processed. The data subject must also be informed of the existence of profiling and the consequences of such profiling. If the personal data are obtained from the data subjects, they must also be informed whether they are obliged to provide them and of the consequences of not doing so.”

In the case at hand, it can be verified that the responding party did not provide correct information regarding the processing. The informative clause referred to, which would have been included in the “employee portal” of the company in October 2021, has significant defects. These are further corroborated by the amendment made to the version of the informative clause, undated, but prepared following the information request from this Agency and as stated in the preliminary actions report sent to the workers in March 2022:

- It does not include which processing operations are subject to this informative clause. In fact, the only specific reference to the processing of the fingerprint comes from a very brief mention in paragraph 3

“A fingerprint reader is installed for access to offices.” It does not indicate whether it is activated or whether it collects the fingerprint and, of course, does not include the fingerprint data among those subject to processing.

In contrast, the subsequent clause contains a specific reference to the processing of the “fingerprint for work time control.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
32/51

In this regard, it is important to note that the informative clause seems to refer to a plurality of treatments, which are encompassed in a single document drafted in a very concise manner. The treatments carried out are not specified, and for all of them, a legitimizing basis applies, which would be the execution of the contract. Furthermore, it states that the processing of personal data is carried out for multiple purposes:

- o Manage the employment relationship with the company's employees.
- o Administrative accounting management of employee data.
- o Payroll preparation.
- o Prevention of occupational risks.
- o Training

- In the first informative clause, joint information was provided for what were supposed to be multiple treatments of personal data carried out by the company. Well, for all of them, the original document simply informed that the basis for legitimization was the expression "Labor contractual relationship." However, in the subsequent version, this has been corrected, and specifically referring to the processing of fingerprint data, it states that the legitimization would come from "compliance with a legal obligation (Article 34.9 of the Workers' Statute), regarding the control of working hours." As can be seen, a completely different legitimizing basis.

In fact, upon consulting the Record of Processing Activities provided by the responding party, in the processing "Access control and working hours through fingerprint," the field "Legitimization of processing operations" states "compliance with a legal obligation (Article 34.9 of the Workers' Statute)."

For all these reasons, the duty to inform workers was not fulfilled in this aspect in the initial information provided. In this regard, it should be recalled that the aforementioned Article 13.2.e) of the GDPR establishes that it must be informed whether "the communication of personal data is a legal or contractual requirement, or a necessary requirement to subscribe to a contract, and whether the data subject is obliged to provide the personal data and is informed of the possible consequences of not providing such data."

- Regarding the data retention period, the initial version of the informative clause stated, "The data provided will be retained as long as the contractual relationship lasts and for the necessary years to comply with legal obligations." This, in addition, as indicated above, in relation to the multiple treatments that were carried out. However, in the subsequent version, it clarifies what the retention and blocking periods are, specifying the total period in years: "The data will be retained as long as the employment relationship lasts. Data regarding working hours will be retained blocked and pseudonymized for the time required by legal compliance (4 years)."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

33/51

- Neither in the initial version of the clause nor in the subsequent one is there any information about the right to lodge a complaint with the supervisory authority (Article 13.2.d).

For all these reasons, it cannot be considered that the responding party has fulfilled its information

obligations under Article 13 of the GDPR. It is also noteworthy that the text of the email sent by the company makes only a reference to the "update of the update of its data protection policies," with no reference whatsoever to the implementation of a timekeeping system using fingerprints (which would surely have encouraged the consultation of the informative clause that, as seen, was totally defective).

VII Lack of information. Article 13 GDPR Qualification and classification of the infringement

In accordance with the evidence available at this moment in the sanctioning procedure, it is considered that the responding party has omitted the information related to the data processing it carries out, thereby violating Article 13 of the GDPR.

The known facts constitute an infringement, attributable to the responding party, classified under Article 83.5 of the GDPR, which stipulates the following:

"5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

b) the rights of data subjects under Articles 12 to 22;"

For the purposes of the limitation period for infringements, the infringement attributed prescribes after three years, in accordance with Article 72.h) of the LOPDGDD, which qualifies the following conduct as very serious:

"h) The omission of the duty to inform the affected party about the processing of their personal data in accordance with the provisions of Articles 13 and 14 of Regulation (EU) 2016/679 and 12 of this organic law."

VIII Lack of information. Article 13 GDPR. Sanction

This infringement may be sanctioned with a fine of up to 20 million EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.5 of the GDPR. Furthermore, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/51

-

The duration of the infringement. It is estimated that it lasted at least from October 2021 (date of the original clause submission) until March 2022 (which contains the revised version) (art. 83.2.a) of the GDPR).

-

The category of personal data affected by the infringement. It should be noted that the fingerprint is a biometric data and according to Article 9 of the GDPR, "the processing of biometric data aimed at uniquely identifying a natural person" is considered as special categories of data (Article 83.2.g) of the GDPR).

In accordance with these criteria, it is estimated that the corresponding sanction is a fine of TWO HUNDRED THOUSAND EUROS (€200,000).

IX Lack of security measures. Article 32 GDPR. Unfulfilled obligation

Regarding the application of data protection regulations to the case presented, it should be noted that the GDPR, in its Article 32, requires data controllers to adopt the necessary security measures to ensure that processing is in compliance with current regulations, as well as to ensure that any person acting under the authority of the controller or the processor and having access to personal data can only process them following the instructions of the controller.

Article 32 "Security of processing" of the GDPR states:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical

and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/51

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements established in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law. Article 32 does not establish static security measures; it is for the controller to determine the necessary security measures to incorporate the ability to ensure the confidentiality, integrity, and availability of personal data. Therefore, the same data processing may involve different security measures depending on the specificities in which such data processing takes place.

In line with these provisions, Recital 75 of the GDPR states: The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social detriment; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health or data about sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, preferences or personal interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable persons, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.

Furthermore, Recital 83 of the GDPR states: In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as destruction, loss, or

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial damages. (the underlining is ours)

In short, the first step in determining security measures will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating risks associated with data processing.

The principle of data security requires the application of appropriate technical or organizational measures in the processing of personal data to protect such data against unauthorized or unlawful access, use, modification, dissemination, loss, destruction, or accidental damage. In this regard, security measures are key to ensuring the fundamental right to data protection. The existence of the fundamental right to data protection is not possible if the confidentiality, integrity, and availability of such data cannot be guaranteed.

It should not be forgotten that, in accordance with Article 32.1 of the cited GDPR, the technical and organizational measures to be applied to incorporate the ability to ensure an adequate level of security relative to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons.

Therefore, the party being claimed against, when assessing risks and determining the appropriate technical and organizational measures to include the ability to ensure an adequate level of security relative to the risk, is obliged to take into account the specific activity being carried out and the type of data being processed.

Thus, derived from the activity it engages in, the party being claimed against is obliged to conduct a highly specialized risk analysis and implement appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its activity for the rights and freedoms of individuals.

In the present case, during the investigation carried out by this Agency, the following has been verified in relation to the security of the system:

- a. The identifying data of the employee and its fingerprint hash are stored and related.
- b. CTC has not demonstrated how the deletion of the fingerprint is guaranteed after its capture.
- c. As detailed in the preliminary investigation report, it is noted that the fingerprint hash is located in a different table from the table where the identifying data of the employees are found. However, it has not been possible to verify the possible security measures that may be in place to separate access to both tables.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Thus, the party being claimed against has not demonstrated the existence of technical and organizational measures regarding the security of personal data processing.

X Qualification and classification for the purposes of the prescription of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

- a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors

referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

XI Lack of security measures Article 32 GDPR.

This infringement may be sanctioned with a fine of up to €10 million or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

Furthermore, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/51

-

Duration of the infringement. It is believed to have lasted at least since October 2021 (date of the sending of the original clause), without the inspector having confirmed its cessation at any time. (art. 83.2.a) of the GDPR).

-

The category of personal data affected by the infringement. It should be noted that a fingerprint is a biometric data and according to Article 9 of the GDPR, “the processing of biometric data aimed at uniquely identifying a natural person” is considered a special category of data. In this regard, the risk situation created by the lack of security measures is greater concerning data that are not considered special (Article 83.2.g) of the GDPR).

Both in the initiation agreement and in the proposed resolution of this file, it was included as one of the breaches within this infringement that the information provided by CTC indicated access by some users who were not listed among the privileged access users provided, both to the application and to the database server.

However, throughout this procedure, the respondent has provided information and documentation that have led to the conclusion that it cannot be determined with total certainty the access of some users who are not listed among the privileged access users provided, both to the application and to the database server.

Consequently, although the initiation agreement of this resolution proposed a sanction of €100,000 for the breach of Article 32, after the aforementioned assessment, the amount is set at SIXTY-FIVE THOUSAND EUROS (€65,000).

XII Impact assessment regarding data protection. Article 35 GDPR

Unfulfilled obligation

Obligation to carry out and exceed a data protection impact assessment.

Article 35.1 of the GDPR states that “When it is likely that a type of processing, in particular if it uses new technologies, by its nature, scope, context, or purposes, entails a high risk to the rights and freedoms of natural persons, the data controller shall carry out, prior to the processing, an assessment of the impact of the processing operations on the protection of personal data. A single assessment may address a series of similar processing operations that entail similar high risks.”

In section 3 of said Article 35, the circumstances in which the preparation of the impact assessment is mandatory are listed:

“a) systematic and comprehensive evaluation of personal aspects of natural persons based on

automated processing, such as profiling, and on which decisions are based that produce legal effects concerning the natural persons or that significantly affect them in a similar manner;
b) large-scale processing of special categories of data referred to in Article 9, paragraph 1, or of personal data relating to criminal convictions and offenses referred to in Article 10, or
c) systematic large-scale observation of a publicly accessible area.”

In this procedure, the need to prepare a data protection impact assessment is not questioned by the respondent, who has also submitted the one prepared in relation to this processing. Article 35.7 GDPR outlines the minimum content that must be included:

“a) a systematic description of the intended processing operations and the purposes of the processing, including, where appropriate, the legitimate interest pursued by the data controller;
b) an assessment of the necessity and proportionality of the processing operations in relation to their purpose;
c) an assessment of the risks to the rights and freedoms of the data subjects referred to in paragraph 1, and
d) the measures envisaged to address the risks, including safeguards, security measures, and mechanisms that ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of the data subjects and other affected persons.”

Before implementing a data processing based on this highly intrusive technology, it is also necessary to audit its operation beforehand, not in isolation but within the framework of the specific processing in which it will be used.

The data protection impact assessment (DPIA) thus appears as the tool required by the GDPR to ensure compliance with this aspect of processing, as established in the aforementioned paragraph 1 of Article 35 of the GDPR.

The processing of biometric data is considered high-risk, pursuant to Article 35.4 of the GDPR, so it must be assumed that the processing carried out in this case by CTC should have been preceded by the completion and passing of a valid impact assessment, which included at least the sections provided for in Article 35.7 of the GDPR. This implies that it is not enough to carry out a DPIA; it must be passed to comply with the GDPR.

For these purposes, this Agency has published a document titled “Lists of types of data processing that require a data protection impact assessment.” This list is based on the criteria established by the Article 29 Working Party in the WP248 guidelines “Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing ‘likely results in a high risk’ for the purposes of the GDPR,” complements it, and should be understood as a non-exhaustive list. Within it is found:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/51

“5. Treatments involving the use of biometric data for the purpose of uniquely identifying a natural person.”

This assessment shall be carried out prior to the commencement of the processing, without prejudice to the fact that it must be understood as a continuous or periodic assessment, in the sense established by Article 35.11 of the GDPR, which states: “Where necessary, the controller shall examine whether the processing is in compliance with the data protection impact assessment, at least when there is a change in the risk posed by the processing operations.”

A DPIA must meet the minimum requirements or content outlined in Article 35.7 of the GDPR, which states:

“The assessment must include at least:

a) a systematic description of the intended processing operations and the purposes of the processing, including, where appropriate, the legitimate interest pursued by the data controller;
b) an assessment of the necessity and proportionality of the processing operations in relation to their purpose;

- c) an assessment of the risks to the rights and freedoms of the data subjects referred to in paragraph 1; and
- d) the measures envisaged to address the risks, including safeguards, security measures, and mechanisms to ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of the data subjects and other affected persons.”

In summary, the successful completion of a DPIA requires that the controller of high-risk processing documents in writing that it surpasses the assessment of suitability, necessity, and proportionality of the processing, and that it manages from the design the specific risks of the processing, with the practical application of measures aimed at them in such a way as to ensure an acceptable risk threshold throughout the lifecycle of the processing, as established in Article 35 of the GDPR.

Furthermore, it obliges prior consultation with the supervisory authority in the event that the controller has not taken measures to mitigate the risk in accordance with Article 36 of the GDPR.

To analyze CTC's compliance with this obligation, it must start from the consideration made by the controller, which has already been rebutted in previous sections of this resolution, that the controller was not processing data classified as special under Article 9 of the GDPR. As has been demonstrated, the processing of biometric data falls into that category of data, without any distinction being applicable, for these purposes, between identification and authentication.

Having established this factor, from the outset, the validity of the document presented by the controller as a “data protection impact assessment” concerning personal data must be dismissed. This is because at no time does this document base itself on the processing of special category personal data such as biometric data. Consequently, the assessment could not have taken into account crucial aspects that should have been analyzed, including:

- Whether any of the grounds for lifting the prohibition on processing those categories of personal data, as provided in Article 9.2 of the GDPR, apply.
- A correct identification and analysis of risks concerning the referenced processing regarding these categories of personal data, which must be taken into consideration along with the other elements involved in the processing of personal data, and how they may affect the rights and freedoms of the data subjects.
- The technical and organizational measures of all kinds, with express mention of the specific security measures inherent to the processing of these data.

What has been presented leads to the conclusion that it cannot in any way be considered a valid data protection impact assessment when it is based on premises in which the data controller does not take into account that it is dealing with the processing of special categories of personal data, with all that this entails regarding compliance with the GDPR and risk management.

One of the obligations that corresponds to every data controller is to ensure that the processing respects the principles set forth in Article 5 of the GDPR. In the case of biometric data, due to being of special category and high risk, it is essential to highlight the fundamental importance of respecting the principle of data minimization, as provided in Article 5.1.c), which states:

“1. Personal data shall be:

- a) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed (‘data minimization’).”

Respecting this principle must be the starting point for the initiation of any processing, with the controller needing to first consider whether this processing will truly be necessary, appropriate, and proportional before commencing it. If this processing is of high risk - as is the case with biometric data - this prior assessment of necessity and proportionality must be reflected in a specific document called a data protection impact assessment, in accordance with the provisions of Article 35.7.b) of the GDPR, which states that “an assessment of the necessity and proportionality of the processing operations in relation to their purpose must be carried out and surpassed.”

This is confirmed by Recital 39 of the GDPR, which emphasizes the importance of the processing being necessary, stating that “Personal data should only be processed if the purpose of the processing cannot reasonably be achieved by other means.”

In the same vein, the Article 29 Working Party, in its Opinion 3/2012 on the evolution of biometric technologies, states that “When analyzing the proportionality of a proposed biometric system, it is essential to first consider whether the system is necessary to address the identified need, that is, whether it is essential to satisfy that need, and not just the most suitable or cost-effective. A second factor to take into account is the likelihood that the system will be effective in addressing the need in question in light of the specific characteristics of the biometric technology to be used. A third aspect to weigh is whether the resulting loss of privacy is proportional to the expected benefits. If the benefit is relatively minor, such as increased convenience or slight savings, then the loss of privacy is not appropriate. The fourth aspect to evaluate the adequacy of a biometric system is to consider whether a less invasive means of achieving the desired end would suffice.”

This idea is reiterated in paragraph 72 of Guidelines 3/2019 on the processing of personal data through video devices, dated 29/01/2020, from the European Data Protection Board (EDPB), which states: “The use of biometric data and, in particular, facial recognition, poses significant risks to the rights of data subjects. It is essential that the use of such technologies occurs in full compliance with the principles of lawfulness, necessity, proportionality, and data minimization as established by the GDPR. Although the use of these technologies may be perceived as particularly effective, data controllers must first assess the impact on fundamental rights and freedoms and consider less intrusive means of achieving their legitimate purpose of processing. In other words, it is necessary to address the question of whether this biometric application is truly indispensable and necessary, or merely ‘convenient.’

Since the processing of biometric data involves restricting the rights and freedoms of data subjects, the obligation to process only “personal data that are adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed” as provided by the principle of data minimization/processing in Article 5.1(c) of the GDPR, must be interpreted in accordance with the established jurisprudence of our Constitutional Court regarding the necessity of confirming that any restrictive measure of fundamental rights (biometric processing in this case) surpasses what is referred to as “the triple test of proportionality.”

This implies that, first and foremost, it is necessary to ascertain whether it meets the following three requirements or conditions referred to by the Constitutional Court: “whether such a measure is capable of achieving the proposed objective (suitability test); whether, furthermore, it is necessary, in the sense that there is no other more moderate measure to achieve such purpose with equal effectiveness (necessity test); and, finally, whether it is balanced or proportionate, as it derives more benefits or advantages for the general interest than harms to other conflicting goods or values (strict sense proportionality test).”

Document submitted by the respondent.

Upon analyzing the impact assessment provided by the respondent, it can be observed that it suffers from significant defects:

First of all, it is necessary to make it clear that a data protection impact assessment is not merely a formal document included as a preliminary step before processing. On the contrary, it is the document that reflects an analysis that must begin with a criterion as basic as whether it is necessary to carry out the processing of personal data for the activity in question. If this initial analysis is not passed, the processing should not be carried out or continued.

Next, if it is essential to carry out the processing of personal data, an analysis must be conducted regarding the type of personal data being processed. This is because, along with other elements, it will

determine the risks that such processing entails and that must be evaluated by the data controller. In light of these risks, an analysis of the necessity, suitability, and proportionality must be conducted, so that a result is obtained which determines whether the risks posed by the processing, and based on the established organizational and security measures, advise for or against its execution.

This brings us back to the concept of data protection impact assessment as both a material and formal concept.

Formal because the existence of a document that synthesizes it is necessary, accompanied by a set of documents that, due to proactive responsibility, prove its execution. Among others, the documentation prior to the DPIA must be present, which reflects the need for the decision to carry out the DPIA; likewise, all documentation prepared in connection with the execution of the DPIA and justifying the results obtained in the DPIA and the measures adopted in this regard is required, including documentation related to the participation of the Data Protection Officer, if applicable, in its preparation.

And material because it must carry out the analyses mentioned above and contain a verdict that allows for the processing to take place. That is to say, the impact assessment is not just a document that must be prepared, but a judgment that must be passed. Only if this judgment is passed, that is, if it is concluded that the existing risks are manageable based on the established technical and organizational measures of all kinds, can the processing be carried out under the planned conditions. And, in the event that the judgment is passed, additional reactive measures must also be foreseen, so that, in case of the materialization of risks, the impact on the rights and freedoms of the data subjects is avoided or minimized.

Well then, regarding the document provided by the responding party, the purposes of the processing are not described. For these purposes, the only reference contained in the document is to indicate that the processing would be legitimized by the fulfillment of a legal obligation (Workers' Statute) and an indication of "The purpose to be covered requires all the data to be collected and for all persons/interested parties affected (data minimization principle)," followed by the expression "YES."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/51

Need and Proportionality

a.

Need

The impact assessment provided by the responsible party does not contain a genuine judgment regarding the necessity and proportionality of the processing in question. For these purposes, the document contains only the following explanation:

"Other systems have been discarded, e.g., card punching, because after experience with it, conflict situations arose. This is a service with a high turnover of personnel. When the card system was used for clocking in, at times it was lent to other individuals who were not the cardholder, resulting in the presence of unauthorized personnel in the work area, with all the risks that entails for occupational safety. The use of fingerprint recognition is the system that allows avoiding these criminal situations and ensures compliance with labor regulations and prevents unauthorized access."

The necessity implies that a combined evaluation, based on facts, is required regarding the effectiveness of the measure for the intended objective and whether it is less intrusive compared to other options to achieve the same goal.

Necessity should not be confused with the utility of the system. It may be that fingerprint detection facilitates not having to carry a card, that it takes a few seconds less to access, that it is automatic and instantaneous, and not excessively costly. Obviously, a fingerprint system can be useful, but it does not have to be objectively necessary (the latter being what truly must be present).

As stated in Opinion 3/2012 on the evolution of biometric technologies by the Article 29 Working Party, it must be examined "whether it is essential to meet that need, and not just the most appropriate or cost-effective." Options and alternatives must be analyzed before establishing a new system that

imposes an excessive limitation on the rights of each user when less invasive means of privacy may exist, and not opting for what is practical or agile and comfortable when the rights of the holders are at stake.

That a previously established system for achieving a purpose is ineffective, as claimed by the responding party regarding its card punching system, does not mean that there are no other systems that are effective without the need for biometric processing. All of them must be considered, with a detailed description of them, and not just the one that they previously assert was ineffective.

The jurisprudence of the CJEU applies a strict necessity assessment for any limitation on the exercise of the rights to the protection of personal data and respect for private life in relation to the processing of personal data: "exceptions and limitations concerning the protection of personal data must be applied only to the extent that they are strictly necessary." The ECtHR applies a strict necessity assessment based on the context and all existing circumstances, as in the case of secret surveillance measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/51

In this regard, none of this is addressed in the provided document. It merely states that the fingerprint clocking system would be justified by alleged problems that could arise from the sharing of cards among workers. In relation to this aspect, it does not explain why some other supervision system that could prevent this problem is not feasible and why, ultimately, the processing of fingerprint data is essential and why other less intrusive systems than the processing of biometric data cannot be used. Consequently, if there are available alternatives for all fans to choose non-biometric access at any given time, and a free, explicit, and specific consent is articulated that allows opting between these other less intrusive methods and the biometric ones, this implies that the processing of biometric data is not necessary for the purpose of controlling the identity of those accessing the cheering section. In no case is the necessity judgment surpassed because biometric processing is not necessary.

b.

Suitability.

The principle of suitability implies the need to assess that there is a logical and direct link between the processing and the objective pursued. In this sense, the only explanation provided by the responding party in this regard is as follows:

"Suitability judgment: to achieve the objective of access control and working hours, the system through the hash of the fingerprint has proven to be adequate for the purpose pursued. The effectiveness threshold that should be reached to comply with the purposes of the processing must be practically 100%; it is about fulfilling a legal obligation and ensuring safety in the workplace. We believe that the effectiveness of this system helps us reach this threshold."

The responding party adds nothing more in this regard, limiting itself to asserting the effectiveness of a system like the one established for clocking in. It does not detail why this is the suitable system, particularly in relation to the risks it entails, nor does it specify why it considers the effectiveness of the system to be total. In fact, it does not claim that such effectiveness is complete but states that "The effectiveness threshold that should be reached to comply with the purposes of the processing must be practically 100%." That is, it does not prove its effectiveness but merely declares an objective to be achieved.

c.

Proportionality

Once a legislative measure is considered necessary, it must be analyzed in terms of its proportionality. An evaluation of proportionality generally involves assessing what "safeguards" should accompany a measure (for example, regarding surveillance) to reduce the risks posed by the proposed measure to the rights and fundamental freedoms of the affected individuals to an "acceptable"/proportional level. Another factor that must be taken into account in the evaluation of the proportionality of a proposed measure is the effectiveness of existing measures above the proposed one.

C/ Jorge Juan, 6

If there are already measures in place for a similar or identical purpose, their effectiveness must be systematically evaluated as part of the proportionality assessment. Without this evaluation of the effectiveness of existing measures that pursue a similar or the same objective, it cannot be considered that the proportionality assessment of a new measure has been properly conducted.

There must be a logical link between the measure and the legitimate objective pursued. In order to respect the principle of proportionality, the advantages resulting from the measure must not be outweighed by the disadvantages that the measure causes concerning the exercise of fundamental rights. One of the factors that plays a role in proportionality is the effectiveness of existing measures, above the proposed one; if there are already measures in the same context for a similar or identical purpose, they must be considered; otherwise, the proportionality assessment has not been properly conducted.

As can be easily observed, the impact assessment provided does not deduce any judgment regarding proportionality. In this regard, the Data Protection Guide in Labor Relations, from this AEPD (May 2021), clarifies the following in its section on "Biometric Data":

"4. Storage should preferably be done on a personal device rather than resorting to centralized storage. A specific encryption key for reading devices must be used to effectively protect this data against any unauthorized access."

In the case at hand, we are faced with a centralized system. Furthermore, nothing regarding the judgment of proportionality appears in the impact assessment provided by the data controller.

Risk Analysis

Article 35.7.d) of the GDPR establishes the following as part of the minimum content of the data protection impact assessment:

"d) the measures planned to address the risks, including safeguards, security measures, and mechanisms that ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of the data subjects and other affected persons."

Observing the corresponding section of the provided impact assessment document, it is concluded that a very partial view of the risks has been included, including (apart from the generic risk of "not carrying out an impact assessment," those related to the security of information systems (possible cyberattacks, breaches, etc.).

On the contrary, nothing is included about the safeguards and mechanisms that ensure the protection of personal data. Nothing is mentioned regarding the possible handling of the stored information concerning biometric data or any other aspect apart from information security. Nor is there any analysis of the risks from the perspective of the rights and interests of the data subjects and affected persons.

Based on the above, it cannot be considered that the data controller has fulfilled its obligation to carry out and surpass a data protection impact assessment concerning the processing of biometric data.

XIII Classification of the infringement of Article 35 GDPR

The aforementioned infringement of Article 35 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to

2% of the total annual global turnover of the previous financial year, opting for the higher amount:

b) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years:

t) The processing of personal data without having carried out the impact assessment of the processing operations on the protection of personal data in cases where it is required."

XIV Lack of impact assessment Article 35 GDPR.

This infringement may be sanctioned with a fine of up to €10 million or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.4 of the GDPR.

Furthermore, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/51

-

Duration of the infringement. It is believed to have lasted at least since October 2021 (date of the sending of the original clause), with the inspector not having verified its cessation at any time. (art. 83.2.a)

-

The category of personal data affected by the infringement. It should be noted that a fingerprint is a biometric data and according to Article 9 of the GDPR, "the processing of genetic data, biometric data aimed at uniquely identifying a natural person," is considered as special categories of data. In this regard, the risk situation created by the lack of security measures is aggravated concerning data that do not have the consideration of special (Article 83.2.g)

According to these criteria, it is estimated that the corresponding sanction is a fine of ONE HUNDRED THOUSAND EUROS (€100,000)

XV Adoption of measures

Once the infringement is confirmed, it is agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...". The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

Specifically, based on the observed infringements, the following measures are established, with a compliance deadline of SIX MONTHS:

- Inform all workers adequately, including all aspects that have not been included so far, in accordance with the details provided in the legal grounds of this resolution

- Establish the necessary security measures to prevent access by personnel not expressly authorized, as well as to ensure the deletion of the fingerprint after its capture. Also, to separate access to the tables containing the hash of the fingerprints and the identifying data of the workers.

- Prepare a data protection impact assessment that contains all the aspects provided for in Article 35 of the GDPR, particularly taking into account the defects pointed out in this resolution.

Additionally, and in accordance with Articles 90.3 of the LPCAP, and 58.2.f) of the GDPR, this resolution agrees that within ten days from its notification, the respondent shall temporarily or

definitively limit the processing of the time control system through fingerprinting, as long as it does not adequately inform the workers, until it carries out and surpasses a valid data protection impact assessment of the processing, which takes into account the risks to the rights and freedoms of employees and the appropriate measures and guarantees for its processing, or even if it is carried out, it must carry out the consultation provision established in Article 36 of the GDPR and ultimately, until it complies with data protection regulations. In this regard, the Agency has recently published a guide on attendance control through biometric processing systems, which is available on its website, indicating the necessary requirements to establish a system of these characteristics.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection

RESOLVES

:

FIRST: TO IMPOSE on CTC EXTERNALIZACIÓN, S.L., with NIF B60924131, the following fines:

- For an infringement of Article 13 of the GDPR, classified under Article 83.5 of the GDPR, a fine of €200,000 (TWO HUNDRED THOUSAND euros).
- For an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of €65,000 (SIXTY-FIVE THOUSAND euros)
- For an infringement of Article 35 of the GDPR, classified under Article 83.4 of the GDPR, a fine of €100,000 (ONE HUNDRED THOUSAND euros).

This amounts to a total of €365,000 (THREE HUNDRED SIXTY-FIVE THOUSAND euros).

SECOND: TO ORDER CTC EXTERNALIZACIÓN, S.L., with NIF B60924131, that pursuant to Article 58.2.d) of the GDPR, within 6 months, it must demonstrate compliance with the following measures:

- Inform all workers adequately, including all aspects that have not been included so far, in accordance with the details provided in the legal grounds of this resolution
- Establish the necessary security measures to prevent access by personnel not expressly authorized, as well as to ensure the deletion of the fingerprint after its capture. Also, to separate access to the tables containing the hash of the fingerprints and the identifying data of the workers.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/51

- Prepare a data protection impact assessment that contains all the aspects provided for in Article 35 of the GDPR, particularly taking into account the shortcomings noted in this resolution, and overcome them.
- Comply with data protection regulations.

THIRD. ORDER, in accordance with Articles 90.3 of the LPCAP and 58.2.f) of the GDPR, to CTC EXTERNALIZACIÓN, S.L., with NIF B60924131, that, within ten days from the notification of this resolution, temporarily or definitively limit the processing of the time control system through fingerprinting, as long as it does not adequately inform the workers, until it conducts and surpasses a valid data protection impact assessment of the processing, which takes into account the risks to the rights and freedoms of employees and the appropriate measures and guarantees for its processing, or even if it is carried out, it must carry out the consultation provision established in Article 36 of the GDPR and, ultimately, until it complies with data protection regulations.

FOURTH: NOTIFY this resolution to CTC EXTERNALIZACIÓN, S.L.

FIFTH: This resolution will be enforceable once the period for filing the optional appeal for

reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must fulfill the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed during the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension terminated.

938-21112023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es